

Security+ 1.2 · Non-repudiation

Mestre CyberSec — PDF com Tópicos Complementares CompTIA · 1.2 — Non-repudiation (7:57) · [vídeo original ↗](#) · [YouTube ↗](#)

Conceito Central: Não-repúdio (Non-repudiation) é a garantia irrefutável de que o autor de uma ação, transação ou mensagem não pode negar sua autoria perante terceiros ou tribunal. Implementação padrão da indústria: cálculo do hash do dado cifrado com a chave PRIVADA do remetente (Assinatura Digital). Qualquer pessoa valida usando a chave PÚBLICA do remetente.

💡 Highlights que a prova cobra

- **Hash só prova integridade; Assinatura Digital prova integridade + AUTOR:** O hash sem chave não vincula a identidade.
- **Criptografia Assimétrica:** Chave privada assina (exclusiva do autor); chave pública valida (pública para todos).
- **Cenário de Negativa:** Se o usuário alegar "*não fui eu quem fez o Pix / assinou o contrato*", a assinatura com sua chave privada invalida legalmente a contestação.

🎯 Dicas de prova & Cenários Típicos

- Palavras-chave da CompTIA: "*cannot dispute*", "*cannot deny origin*", "*irrefutable proof*" = **Non-repudiation**.
- Qual algoritmo usar: Algoritmos assimétricos de assinatura (RSA, ECDSA, Ed25519).
Nunca AES (AES é simétrico, usa a mesma chave secreta compartilhada, não comprovando autoria única).

Cenário clássico: Uma organização precisa provar ao judiciário que um gerente financeiro autorizou uma ordem de pagamento. Solução: Assinatura digital vinculada ao smart card / chave privada do gerente com carimbo de tempo.

 **Além do Vídeo: O que a CompTIA cobra na prova (e o vídeo não**

Por que este aprofundamento é obrigatório para o exame? Os vídeos do Professor Messer duram de 5 a 8 minutos e definem o conceito básico. No exame oficial CompTIA Security+ (SY0-701), as questões colocam cenários com falhas práticas, ataques e limites criptográficos. Entenda os conceitos complementares que a banca exige:

- **1. Por que um Hash SHA-256 PURO NÃO garante Não-Repúdio?**
 - O hash SHA-256 é uma função matemática determinística pública e sem chaves (qualquer pessoa do planeta pode executar).
 - Ele garante **apenas integridade** (se o arquivo sofreu alteração).
 - Se um criminoso adulterar um contrato e gerar um novo hash SHA-256, o hash será matematicamente perfeito. Sem uma chave privada que amarre a identidade de quem gerou o hash, o autor original pode legitimamente dizer: *"Qualquer pessoa pode ter recalculado esse hash, não fui eu"*.
 - **Conclusão de prova:** Hash puro = Integridade. Assinatura Digital (Hash + Chave Privada) = Integridade + Autenticação + Não-repúdio.
- **2. HMAC (Hash-based Message Authentication Code):**
 - O HMAC combina a função hash com uma **chave simétrica secreta compartilhada** entre duas partes (ex: cliente e servidor).
 - Garante Integridade e Autenticidade mútua, **mas NÃO garante não-repúdio perante terceiros**, pois como as duas pontas conhecem exatamente a mesma chave, uma pode acusar a outra de ter gerado a mensagem.
- **3. TSA (Time Stamping Authority - RFC 3161):**
 - Autoridade independente e confiável que gera um **carimbo de tempo criptográfico**.
 - O TSA recebe o hash do documento, concatena com a data/hora exata de seu relógio auditado e assina o pacote com a chave privada da autoridade.
 - **LTV (Long-Term Validation):** Se daqui a 5 anos o contrato for questionado e o certificado do assinante já estiver expirado ou o algoritmo enfraquecido, o TSA prova que a assinatura foi criada no momento exato em que o certificado era plenamente válido.
- **4. Chaves Assimétricas: Qual chave faz o quê?**
 - **Para Confidencialidade (segredo):** Cifra com a chave PÚBLICA do destinatário. Apenas ele decifra com a chave PRIVADA dele.
 - **Para Não-repúdio (assinatura):** Cifra o hash com a chave PRIVADA do remetente. Qualquer pessoa confere com a chave PÚBLICA dele.

- **Para Ambos:** O remetente assina com sua chave privada e depois cifra o resultado com a chave pública do destinatário.

✓ Perguntas de treino comentadas (10 questões)

Gabarito detalhado no final da página. Resolva antes de conferir as respostas.

1. Um executivo sênior alega em juízo que nunca autorizou a transferência de 5 milhões de dólares por e-mail, afirmando que a mensagem foi forjada por terceiros. A equipe forense demonstra que o e-mail foi assinado com a chave privada do executivo vinculada ao seu smart card. Qual propriedade de segurança refuta a alegação do executivo?

- A) Confidencialidade simétrica
- B) Não-repúdio (Non-repudiation)
- C) Disponibilidade com failover
- D) Hashing SHA-256 isolado

2. Uma empresa de software precisa distribuir atualizações de firmware e garantir que os dispositivos aceitem apenas pacotes legítimos e que a empresa não possa alegar que outra pessoa enviou o firmware. O que deve ser implementado?

- A) Assinatura digital do binário usando a chave privada da empresa
- B) Criptografia AES-256 do binário com chave compartilhada
- C) Cálculo de hash MD5 disponibilizado no site
- D) Ofuscação de código com compactação ZIP

3. Por que um hash SHA-256 puro (sem chave ou assinatura) NÃO é suficiente para garantir o não-repúdio de um documento?

- A) Porque o hash só protege dados em movimento, não em repouso
- B) Porque o hash exige duas chaves para ser validado
- C) Porque qualquer pessoa pode recalcular o hash de um documento adulterado
- D) Porque o hash é reversível e pode ser descriptografado

4. Em um esquema de assinatura digital para não-repúdio, qual chave é usada para ASSINAR o resumo criptográfico (digest) e qual é usada pelo destinatário para VALIDAR a assinatura?

- A)** Assina com a chave pública do remetente; valida com a chave privada do remetente
- B)** Assina com a chave privada do destinatário; valida com a chave pública do destinatário
- C)** Assina com a chave privada do remetente; valida com a chave pública do remetente
- D)** Assina com chave simétrica AES compartilhada; valida com a mesma chave

5. Uma organização financeira precisa registrar logs de transações bancárias em conformidade regulatória. Para garantir que nem mesmo os administradores do banco de dados possam alterar ou negar as entradas passadas, qual técnica combinada deve ser utilizada?

- A)** Armazenamento WORM (Write Once, Read Many) assinado digitalmente com carimbo de tempo (timestamping)
- B)** Criptografia reversível com chave armazenada em texto claro
- C)** Backups semanais compactados sem criptografia
- D)** Permissões discricionárias de leitura para todos os usuários

6. Um analista de segurança analisa uma falha de não-repúdio em que um colaborador afirma que outro funcionário usou seu computador para assinar um contrato. Qual controle complementar reforça o não-repúdio do usuário?

- A)** Bloqueio automático de tela e autenticação biométrica/MFA para liberação da chave privada
- B)** Aumento do tamanho do disco rígido
- C)** Troca do cabo Ethernet por Wi-Fi protegido
- D)** Desativação dos logs do sistema operacional

7. Qual elemento da Infraestrutura de Chaves Públicas (PKI) vincula de maneira formal e legal a identidade de uma pessoa à sua chave pública para sustentar o não-repúdio?

- A)** Certificado Digital assinado por uma Autoridade Certificadora (CA)
- B)** Tabela de roteamento do firewall de borda
- C)** Hash MD5 da placa de rede (MAC address)
- D)** Servidor de nomes dinâmico (DDNS)

8. Um contrato digital entre duas empresas foi assinado eletronicamente. Cinco anos depois, uma das partes tenta invalidar o contrato alegando que o algoritmo de hash usado na época era fraco ou o certificado expirou. Qual mecanismo protege a validade jurídica de longo prazo contra essa contestação?

- A)** Carimbo do tempo criptográfico confiável (Time Stamping Authority - TSA) aplicado no momento da assinatura
- B)** Cópia impressa do código-fonte do sistema
- C)** Troca da chave pública por uma chave simétrica secreta
- D)** Reinicialização periódica dos servidores web

9. Se Bob envia uma mensagem criptografada apenas com a chave PÚBLICA de Alice, qual pilar da segurança foi atendido e qual NÃO foi?

- A)** Foi atendida a Confidencialidade; o Não-repúdio do remetente NÃO foi atendido
- B)** Foi atendido o Não-repúdio; a Confidencialidade NÃO foi atendida
- C)** Ambos foram atendidos perfeitamente
- D)** Nenhum objetivo foi atingido

10. Para que Bob consiga enviar uma mensagem a Alice garantindo simultaneamente CONFIDENCIALIDADE e NÃO-REPÚDIO do remetente, qual é o fluxo correto de chaves assimétricas?

- A)** Bob assina a mensagem com sua própria chave privada e cifra o resultado com a chave pública de Alice
- B)** Bob cifra com a chave privada de Alice e assina com a chave pública de Bob
- C)** Bob usa a mesma chave pública tanto para cifrar quanto para assinar
- D)** Alice assina previamente e envia a chave para Bob cifrar

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

- 1) B — Não-repúdio (Non-repudiation).** A chave privada é única e intransferível do executivo. Assinar o hash com ela impede a negação judicial. *Erros das outras: A trata de sigilo simétrico (sem autor único); C é disponibilidade; D hash isolado não prova quem enviou.*
- 2) A — Assinatura digital do binário usando a chave privada da empresa.** Garante autenticidade de origem e que o código não foi adulterado. *Erros das outras: B chave simétrica não distingue quem assinou; C MD5 é vulnerável a colisão e não tem chave; D ofuscação não é mecanismo criptográfico.*
- 3) C — Porque qualquer pessoa pode recalcular o hash de um documento adulterado.** O hash puro não tem chave vinculada. Se o documento for fraudado, qualquer um calcula um hash SHA-256 novo para a fraude. *Erros das outras: A o hash funciona em repouso e trânsito; B hash não usa chave alguma; D hash é estritamente unidirecional (irreversível).*
- 4) C — Assina com a chave privada do remetente; valida com a chave pública do remetente.** Apenas o remetente tem sua chave privada (autoria irrefutável); todos validam com a pública correspondente. *Erros das outras: A inverteria tudo tornando a validação secreta; B o destinatário não assina o que recebe; D simétrico não provê autoria única.*
- 5) A — Armazenamento WORM assinado digitalmente com carimbo de tempo (timestamping).** WORM impede sobrescrita física e o carimbo digital prova quando foi gravado e quem gerou. *Erros das outras: B texto claro expõe credenciais; C sem criptografia viola confidencialidade e integridade; D leitura discricionária ampla viola menor privilégio.*
- 6) A — Bloqueio automático de tela e autenticação biométrica/MFA para liberação da chave privada.** Garante que apenas o titular físico legítimo possa liberar o uso da chave privada. *Erros das outras: B tamanho de disco não afeta autenticação; C cabo vs Wi-Fi não impede acesso físico ao teclado; D desativar logs destrói a auditoria.*
- 7) A — Certificado Digital assinado por uma Autoridade Certificadora (CA).** O certificado X.509 emitido pela CA é o documento oficial que amarra a identidade física/jurídica à chave pública. *Erros das outras: B tabela de roteamento é infraestrutura de rede L3; C MAC address é identificador de hardware L2 facilmente forjável; D DDNS apenas resolve nomes de host.*
- 8) A — Carimbo do tempo criptográfico confiável (Time Stamping Authority - TSA).** O carimbo assinado pela autoridade prova que o documento e a assinatura existiam de forma íntegra no momento em que os certificados eram plenamente válidos (LTV). *Erros das outras: B cópia de código em papel não tem validade matemática em assinatura digital; C chave simétrica destruiria a assinatura digital; D reboot de servidor é irrelevante para PKI.*
- 9) A — Foi atendida a Confidencialidade; o Não-repúdio NÃO foi atendido.** Como a chave pública de Alice é pública, qualquer um na internet pode ter criptografado a mensagem para ela; não há assinatura de Bob. *Erros das outras: B, C e D erram pois a mensagem está confidencial (só Alice abre), mas a origem é anônima/reputável.*
- 10) A — Bob assina a mensagem com sua própria chave privada e cifra o resultado com a chave pública de Alice.** A chave privada de Bob atesta autoria e integridade (não-repúdio); a chave pública de Alice restringe a leitura exclusivamente a Alice (confidencialidade). *Erros das outras: B Bob não tem a chave privada de Alice; C chave pública não assina nada; D Alice não pode assinar algo que ainda não recebeu.*

